Code Review Standards

Document ID	ENG-001
Department	Engineering
Document type	Standard
Owner	VP Engineering
Version	2.1
Status	APPROVED
Effective / last reviewed	2025-07-26
Audience	Engineering staff
Related documents	ENG-006, ENG-008, SEC-007, ENG-015

Summary. Defines how Northstar engineers review code before it merges, including reviewer counts by service tier, response times, pull request size, test coverage, security review by Security Champions, stale pull requests, review etiquette and exceptions for hotfixes.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This standard defines how code is reviewed at Northstar Systems Private Limited before it is merged into a protected branch. Code review catches defects, spreads knowledge, keeps the design consistent and ensures that no single engineer can change production behaviour without a second pair of eyes. The standard applies to every change to source code, infrastructure-as-code, database migration scripts, pipeline definitions in NorthShip, configuration for the Northstar Nexus Platform and documentation stored in version control.

The standard applies to all engineers in Bengaluru, Mumbai and remote locations, and to contractors who commit to Northstar repositories. It works together with the deployment rules in ENG-006, the testing standard in ENG-008, secure development practices in SEC-007 and the engineering tooling guide in ENG-015. Where this standard and a team's own working agreement differ, the stricter rule applies.

2. Definitions

- **Author**: the engineer who opens the pull request (PR).
- **Reviewer**: an engineer who reads the change and records an approval or a request for changes.
- **Approving reviewer**: a reviewer whose approval counts toward the required number. The author cannot be an approving reviewer for their own change.
- **Service tier**: the criticality of the service. Tier-1 is customer-facing and revenue critical, Tier-2 is internal critical and Tier-3 is non-critical.
- **Security Champion**: an engineer in each team trained by Security and named in the team's CODEOWNERS file as the reviewer for security-sensitive changes.
- **Security-sensitive change**: a change to authentication, authorisation, cryptography, secrets handling, or processing of personal data.
- **Changed lines**: lines added plus lines deleted in a PR, excluding generated files and lock files.

- **Stale PR**: a PR with no update for more than 14 days.
- **Protected branch**: `main` and any `release/<version>` branch, where direct pushes are disabled.

3. Roles and Responsibilities

- **Author**: keeps the PR small, writes a clear description, runs tests locally, links the ticket, responds to comments promptly and does not merge without the required approvals.
- **Reviewer**: reviews with care and respect, gives a first response within 1 business day, distinguishes blocking issues from suggestions, and approves only when satisfied.
- **Security Champion**: reviews every security-sensitive change in the team's services.
- **Engineering Manager**: ensures reviews are balanced across the team, tracks review response times and stale PRs, and resolves disagreements that authors and reviewers cannot settle.
- **Tech Lead**: owns the CODEOWNERS file, names the required reviewers for each path and decides when a change needs an Architecture Decision Record.
- **VP Engineering**: owns this standard, approves exceptions and reviews code review metrics each quarter.

4. Review Requirements

4.1 Number of approvals

Service tier	Approving reviewers required	Notes
Tier-1	2	At least 1 reviewer must be from the owning team
Tier-2	1	The reviewer must know the service
Tier-3	1	The reviewer may be from an adjacent team

Tier-1 services need 2 approving reviewers, while all other services need 1. The author cannot approve their own change under any circumstances. If an author pushes new commits after approval, approvals are dismissed automatically when the new commits change application logic, and the reviewers must approve again. Changes that only fix a typo in comments or documentation do not dismiss approvals.

4.2 Required checks

A PR may merge only when all of the following are true:

1 The required number of approving reviewers has approved.
2 All automated checks on the pipeline in NorthShip have passed (build, unit tests, linting, static analysis and dependency scan).
3 New code coverage is at least 80%, as measured by the coverage tool for lines added or changed in the PR.
4 No unresolved blocking comments remain.
5 The branch is up to date with `main`, or the merge queue has re-run the checks on the combined result.
6 For a security-sensitive change, the Security Champion has approved.
7 No new dependency with an unpatched critical vulnerability has been introduced, and the licence of any new dependency is allowed under the open source rules (see ENG-009 for open source use).

4.3 Pull request size

The recommended size of a PR is at most 400 changed lines. Authors should split larger work into a sequence of PRs, each of which builds, passes tests and can be merged on its own. Large mechanical changes, such as automatic renames or code formatting, may exceed 400 lines but must be in a separate PR from behaviour changes and must say so clearly in the description. Reviewers may decline to review a PR above 400 changed lines until the author explains why it cannot be split.

Example: An engineer building a new export feature for Nexus Insight starts with 1,150 changed lines. The Tech Lead asks her to split it into four PRs: the data model and migration (210 lines), the service layer (380 lines), the API endpoint (290 lines) and the UI (270 lines). Each is reviewed within 1 business day and the feature merges behind a feature flag in 5 days.

4.4 Review response time

The first review response must come within 1 business day of the PR being marked ready for review. A response is a comment, an approval or a request for changes; an automatic bot comment does not count. If the reviewer cannot respond in time, the reviewer should say so and name a replacement. The author may ask the Tech Lead to reassign the review after 1 business day without a response.

Tier-1 production fixes may be reviewed on a faster timeline set by the incident commander during an incident. See section 8.

4.5 Stale PRs

PRs with no updates for more than 14 days are flagged automatically in the team channel and in the weekly engineering digest. The author must either update the PR, mark it as draft, or close it within 5 business days of the flag. A closed PR can be reopened. Branches belonging to closed PRs are deleted after 30 days. Engineering Managers review the stale PR list in their weekly team meeting.

5. Security-sensitive Changes

A change that touches authentication, cryptography or the handling of personal data (PII) is security-sensitive and needs review by a Security Champion in addition to the normal approvals. The Security Champion reviews for the following:

- Correct use of NorthID, OAuth 2.0 client credentials and session timeouts.
- Use of approved cryptographic libraries, with AES-256 at rest and TLS 1.2 minimum in transit.
- No secrets in source code. Secrets must be stored in NorthVault or the KMS-backed secret store.
- Personal data is collected only when necessary, logged only in masked form and covered by the retention schedule.
- Input validation, output encoding and error messages that do not leak internal details.

Authors mark a PR as security-sensitive using the PR template checkbox. Reviewers who notice a security-sensitive change that is not marked must add the label and request the Security Champion's review. Security Champions should respond within 1 business day, like any other reviewer.

If a team has no available Security Champion, the PR goes to the Security Engineering queue in NorthDesk, and the review SLA is 2 business days.

Example: A Platform Engineer changes how the Nexus Platform validates API tokens (error NX-1001 behaviour). The PR touches authentication, so it needs two approving reviewers (Tier-1 service) plus Security Champion review. The Security Champion notices that the new code logs the token prefix at INFO level and asks for it to be removed. The author fixes it and the PR merges after 2 days.

6. Author Expectations

1 Write a PR description that explains why the change is needed, what changed, how it was tested, the risk and the rollback plan.
2 Link the NorthDesk ticket or issue for the work. A change with no ticket is not merged.
3 Keep feature branches short-lived. Trunk-based development is the default and branches should last at most 3 days.
4 Self-review the diff before requesting review, and remove debugging code and commented-out blocks.
5 Include or update tests for all new behaviour and bug fixes. A bug fix must include a test that fails before the fix.
6 Update documentation, API specifications and runbooks affected by the change.
7 Respond to every comment, either by changing the code or explaining why not. Mark conversations as resolved only when they are addressed.
8 Do not force-push to a PR after review has started, except to rebase, and say so in a comment.

7. Reviewer Expectations

A good review checks the following, in roughly this order:

1 **Correctness**: does the code do what the ticket requires, including error paths and edge cases?
2 **Design**: does it fit the existing architecture, and does it need an ADR when it affects more than one team or lasts over 12 months?
3 **Tests**: are tests meaningful, deterministic and sufficient? Are flaky tests introduced?
4 **Security and privacy**: see section 5.
5 **Performance and reliability**: query efficiency, timeouts (30 seconds default for requests), retries with backoff, idempotency for POST requests that create resources.
6 **Observability**: logs, metrics and traces are added where needed, and alerts link to a runbook.
7 **Maintainability**: naming, readability, duplication and documentation.
8 **Database changes**: migrations are backwards-compatible (expand and contract) for Tier-1 services and reviewed by the Data Engineering DBA.

Reviewers label comments as **blocking**, **suggestion** or **question**. Only blocking comments prevent approval. Reviewers should explain the reason behind a request, offer an alternative, and acknowledge good work. Comments must be about the code, not the person. Disagreements that remain after two rounds of comments are taken to a call; if the call fails, the Tech Lead decides, and the Engineering Manager decides if the Tech Lead is the author.

8. Emergency and Hotfix Reviews

During a SEV1 or SEV2 incident, a fix may be reviewed under a faster process. The Incident Commander can authorise a single approving reviewer for a Tier-1 hotfix, provided the reviewer is not the author and the reviewer has read the complete diff. The change goes through the Emergency change type (approved by the Engineering Director on call), and a retrospective review

by a second reviewer is completed within 1 business day. Hotfix branches use the name `hotfix/<ticket>`. No hotfix review may skip the automated checks in NorthShip unless the Incident Commander records the reason in the NorthDesk change ticket and the Head of Site Reliability Engineering agrees.

Example: At 23:40 IST a SEV1 appears after a release: the error rate on a payment-routing service rises above 2%. The on-call engineer prepares a one-line fix on `hotfix/ENG-4821`. The Incident Commander approves a single-reviewer process, a senior engineer reviews the diff within 10 minutes, and the change goes out through the emergency path. The second reviewer completes the retrospective review the next morning, within 1 business day.

9. Exceptions

- **Documentation-only changes** in a non-code repository may be merged with 1 approval even for Tier-1 repositories.
- **Automated dependency updates** created by an approved bot may be merged with 1 approving reviewer if the full automated test suite passes, the update is a patch or minor version, and no licence change is involved.
- **Generated code** is reviewed at the generator or template, not the output, but the PR must show that it was regenerated.
- **Coverage below 80%** is allowed only with a written reason in the PR and approval from the Tech Lead; the exception is reported in the monthly engineering metrics.
- **Single-owner repositories**: if only one engineer knows the service, the Engineering Manager names a reviewer from an adjacent team and the owner pairs with them on the first review.
- Any other exception needs written approval from the VP Engineering.

10. Metrics and Governance

The Engineering Managers review these metrics monthly: time to first review, time to merge, share of PRs under 400 changed lines, number of stale PRs, review coverage by Security Champions on security-sensitive changes and escaped defects found in production that were linked to a recent PR. The VP Engineering reviews the data each quarter and may update this standard. Repeated violations, such as merging without required approvals by using administrator rights, are raised with the Engineering Manager and may be treated under the disciplinary procedure in HR-014.

11. Review Workflow Step by Step

1 The author opens a draft PR early if feedback on direction is wanted, and marks it ready for review only when the NorthShip checks pass and the description is complete.

2 The PR template asks for the ticket link, a summary, test evidence, the risk level, the rollback plan and whether the change is security-sensitive. The author ticks each box honestly; reviewers may send back a PR with an incomplete template without reviewing the code.

3 CODEOWNERS assigns the required reviewers automatically. The author may add further reviewers who know the area, but should avoid adding more than four people, since large review groups slow responses and spread responsibility.

4 Reviewers respond within 1 business day. The first pass focuses on design and correctness; later passes focus on detail. Reviewers should raise major design concerns in the first pass rather than in the last.

5 The author addresses comments, pushes follow-up commits and replies to each thread. When all blocking threads are resolved, reviewers re-approve.

6 The author merges using the merge queue, with a squash commit whose message includes the ticket ID. After merge, the author watches the NorthShip pipeline and the release train status in case the change causes a failed build on `main`.
7 If a merged change breaks `main`, the author reverts it within 1 hour or fixes it forward, whichever is faster, and informs the team channel.

11.1 Reviewing infrastructure and migration changes

Infrastructure-as-code and pipeline definition changes are reviewed by an engineer from the Site Reliability Engineering team in addition to the normal approvals, because a wrong pipeline setting can affect many services. Database migration scripts are reviewed by the Data Engineering DBA, who checks that the migration is backwards-compatible for Tier-1 services, runs inside the deployment window and has a tested rollback. Data fixes that change production records need two-person review, and the second person must run the query against a copy first.

Example: A backend engineer adds a new column and a migration to a Tier-1 service. The DBA asks for the migration to be split into an expand step in this release and a contract step in a later release, so that the previous application version keeps working if the release is rolled back. The engineer revises the PR, and the two approving reviewers and the DBA all approve within 2 business days.

12. Frequently Asked Questions

Can the author of a PR approve it? No, the author cannot approve their own change.

How many approvals does a Tier-1 service need? 2 approving reviewers; other services need 1.

What if my PR is 700 lines? The recommended maximum is 400 changed lines. Split it, or explain in the description why it cannot be split.

When is a PR flagged as stale? When it has had no update for more than 14 days.

13. Related Documents

Deployment windows, change types and rollout rules are in ENG-006. Testing standards are in ENG-008. Secure development practices are in SEC-007. Engineering tooling and templates are in ENG-015. Open source licence rules are in ENG-009.

14. Revision History

Version	Date	Change
1.0	2024-03-04	Initial standard
2.0	2025-01-20	Introduced tier-based reviewer counts and Security Champion review
2.1	2025-07-26	Clarified stale PR handling and hotfix review process